



Vulnerability Assessment &
Penetration Testing (VAPT) Report

Ambledown Financial Services

05th June 2025



TABLE OF CONTENTS

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP.....	3
3.2	TENABLE NESSUS.....	3
3.3	GREENBONE ENTERPRISE	4
	STAY ONE STEP AHEAD OF ATTACKERS	4
3.4	OWASP.....	5
3.5	BRUTE FORCE	5
	APPLICATIONS USED IN BRUTE FORCE INCLUDE:	5
4	SCOPE OF SERVERS.....	6
4.1	AMBLEDOWN DOMAIN CONTROLLER – 192.168.0.22	6
4.2	AMBLEDOWN FIREWALL INTERNAL – 192.168.0.1 (GREENBONE).....	6
4.3	AMBLEDOWN HO FIREWALL – 41.169.103.84	6
4.4	AMBLEDOWN LIVE SERVER – 102.67.139.234	10
4.5	AMBLEDOWN UAT SERVER – 154.0.171.224	12
5	NETWORK CONFIGURATION AND SECURITY POLICIES.....	17
5.1	INTERNAL NETWORK SCAN	17
5.2	AMBLEDOWN USER LIST	17
5.3	PASSWORD POLICIES	19
5.4	DOMAIN POLICIES.....	20
5.5	DOMAIN ADMIN USERS	20
5.6	SYSTEM INFORMATION	21
5.7	SERVER WINDOWS UPDATES	21
5.8	SERVER OS.....	22
5.9	FORTIGATE FIREWALL.....	22
5.10	FIREWALL INFORMATION.....	22
5.11	WIRELESS NETWORK	23
6	REPORTING CONCLUSION	24
7	AUDITORS	25



1 EXECUTIVE SUMMARY

The objective of this assessment was to identify security vulnerabilities, business logic flaws, and missing best security practices. The tests were conducted from the perspective of an attacker or malicious user, without causing any disruption to the functionality or performance of the application or network. Additionally, a comprehensive scan of the infrastructure was performed to simulate a real-world attack scenario, such as an internal network breach or exposure on a shared public subnet.

The assessment, including scans and testing, was carried out over seven (7) business days to ensure a thorough and methodical audit. These scans also examined unidentified connectivity options, such as packet SYN requests.

The overall results will be published below.
Recommendations are offered and mentioned throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- **Ambledown Domain Controller – 192.168.0.22**
- **Ambledown Firewall Internal – 192.168.0.1**
- **Ambledown HO Firewall – 41.169.103.84**
- **Ambledown Live Server – 102.67.139.234**
- **Ambledown UAT Server – 154.0.171.224**

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

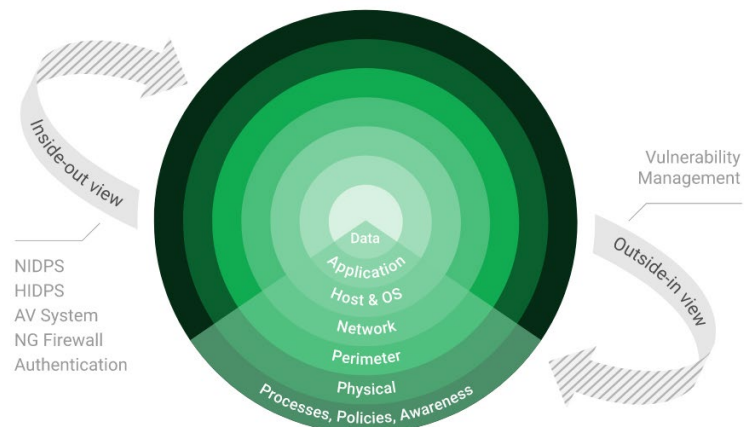
3.2 Tenable Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.



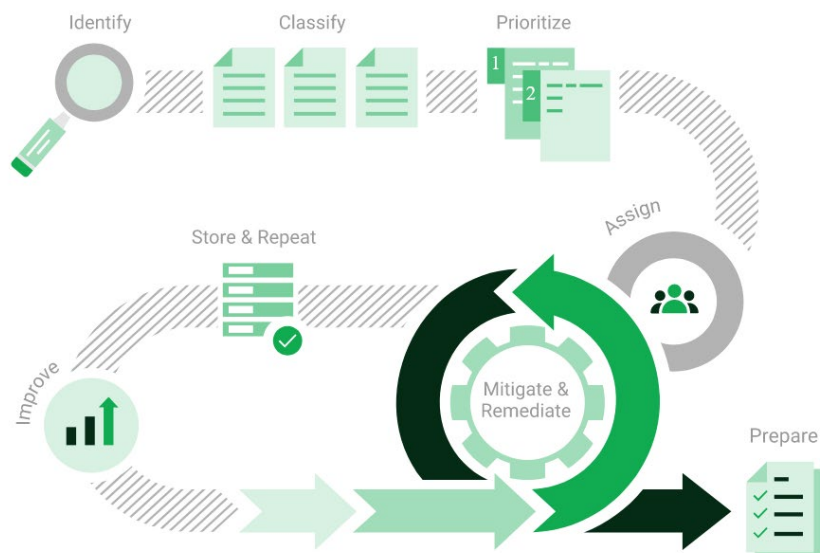
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



STAY ONE STEP AHEAD OF ATTACKERS

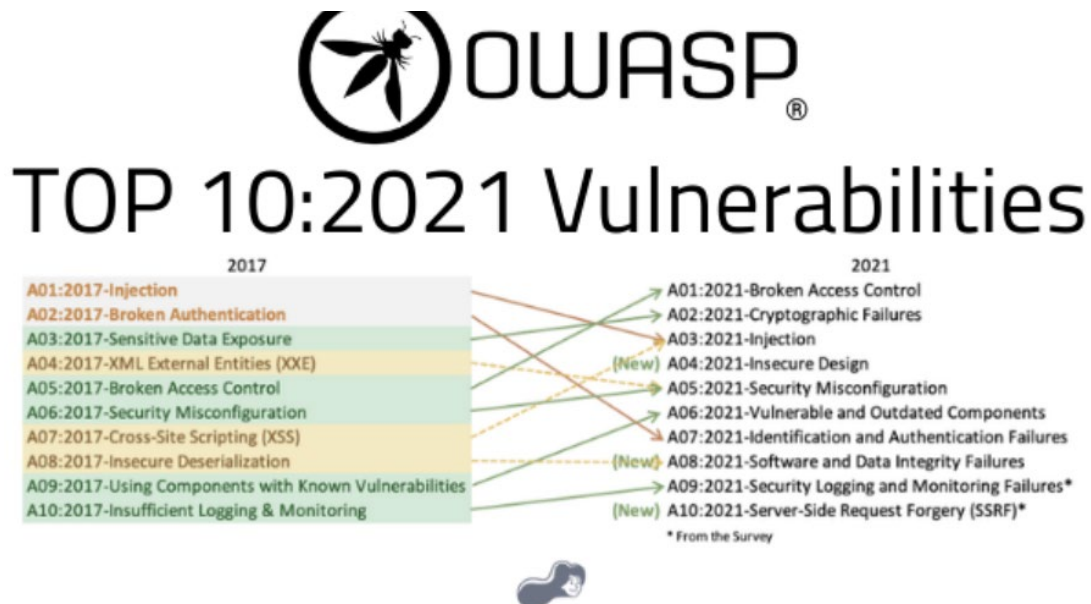
IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.



The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.

3.4 OWASP

The Open Web Application Security Project (OWASP) is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



3.5 Brute Force

- A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.
- The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts. Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers.

Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 2.5 Million + Username and password combos are used to Brute force application like RDP, SSH etc.



4 SCOPE OF SERVERS

4.1 Ambledown Domain Controller – 192.168.0.22

We have performed the following types of scans / attacks on the production server namely:

- Greenbone Enterprise - The Greenbone Report will be provided as a separate attachment.

4.2 Ambledown Firewall Internal – 192.168.0.1 (GREENBONE)

We have performed the following types of scans / attacks on the production server namely:

- Greenbone Enterprise - The Greenbone Report will be provided as a separate attachment.

4.3 Ambledown HO Firewall – 41.169.103.84

We have performed the following types of scans / attacks on the production server namely:

- Greenbone Enterprise - The Greenbone Report will be provided as a separate attachment.
- OWASP – The OWASP Report will be provided as a separate attachment.
- Port Mapping – Nmap / Zenmap (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments – Tenable Nessus.
- Brute Force Attacks – Hydra.

■ Port Mapping – Nmap / Zenmap

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

▼	Port	Protocol	State ▼	Service	Version
●	21	tcp	open	ftp	FileZilla ftpd 0.9.34 beta
●	22	tcp	open	ssh	Bitvise WinSSHD 9.42 (FlowSsh 9.42; protocol 2.0)
●	80	tcp	open	http	Microsoft IIS httpd 8.5
●	443	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
●	445	tcp	open	microsoft-ds	Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
●	1723	tcp	open	pptp	
●	8008	tcp	open	http	Apache httpd 2.4.41 ((Ubuntu) mod_wsgi/4.6.8 Python/3.8)

Remote Operating System Detection:

- Used Port: 21/tcp (open)
- Used Port: 22/tcp (open)
- Used Port: 80/tcp (open)



- Used Port: 443/tsp (open)
- Used Port: 445/tsp (open)
- Used Port: 1723/tsp (open)
- Used Port: 8008/tsp (open)

▪ Vulnerability Assessment – Tenable Nessus

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.

41.169.103.84



Vulnerabilities					Total: 58
SEVERITY	CVSS V3.0	VDR SCORE	IPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	-	-	20007	SSL Version 2 and 3 Protocol Detection
HIGH	7.5	6.1	0.406	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	5.9	7.3	0.9303	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	5.3	-	-	10677	Apache mod_status /server-status Information Disclosure
MEDIUM	5.3	2.2	0.7856	62694	Internet Key Exchange (IKE) Aggressive Mode with Pre-Shared
MEDIUM	5.3	-	-	57608	SMB Signing not required
LOW	3.7	1.4	0.0307	70658	SSH Server CBC Mode Ciphers Enabled
LOW	3.7	-	-	153953	SSH Weak Key Exchange Algorithms Enabled
LOW	3.7	4.5	0.9403	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
LOW	3.4	5.1	0.942	78479	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)
LOW	2.1*	2.2	0.0037	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	-	48204	Apache HTTP Server Version
INFO	N/A	-	-	39521	Backported Security Patch Detection (WWW)
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	54615	Device Type



INFO	N/A	-	-	10092	FTP Server Detection
INFO	N/A	-	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	11935	IPSEC Internet Key Exchange (IKE) Version 1 Detection
INFO	N/A	-	-	42410	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure
INFO	N/A	-	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (rem check)
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	-	50845	OpenSSL Detection
INFO	N/A	-	-	10622	PPTP Detection
INFO	N/A	-	-	122364	Python Remote HTTP Detection
INFO	N/A	-	-	31422	Reverse NAT/Intercepting Proxy Detection
INFO	N/A	-	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	-	10267	SSH Server Type and Version Information



INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	96982	Server Message Block (SMB) Protocol Version 1 Enabled (unauthenticated check)
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	11154	Unknown Service Detection: Banner Retrieval
INFO	N/A	-	-	135860	WMI Not Available
INFO	N/A	-	-	10150	Windows NetBIOS / SMB Remote Host Information Disclosure

* indicates the v3.0 score was not available; the v2.0 score is shown

■ Brute Force

Randomised usernames with a word list containing more than 2.5 million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
[DATA] attacking ssh://41.76.215.242:22/
[STATUS] 584.00 tries/min, 584 tries in 00:01h, 19885 to do in 00:35h, 4 active
[STATUS] 207.00 tries/min, 621 tries in 00:03h, 19848 to do in 01:36h, 4 active
[STATUS] 100.43 tries/min, 703 tries in 00:07h, 19766 to do in 03:17h, 4 active
[STATUS] 58.67 tries/min, 880 tries in 00:15h, 19589 to do in 05:34h, 4 active
[STATUS] 36.68 tries/min, 1137 tries in 00:31h, 19332 to do in 08:48h, 4 active
[STATUS] 28.34 tries/min, 1332 tries in 00:47h, 19137 to do in 11:16h, 4 active
[STATUS] 24.19 tries/min, 1524 tries in 01:03h, 18945 to do in 13:04h, 4 active
[STATUS] 21.73 tries/min, 1717 tries in 01:19h, 18752 to do in 14:23h, 4 active
[STATUS] 19.37 tries/min, 1840 tries in 01:35h, 18629 to do in 16:02h, 4 active
```



As per the HYDRA screen shot above, all know accounts have been scanned and with no passwords found. We are satisfied with the results.

4.4 Ambledown Live Server – 102.67.139.234

We have performed the following types of scans / attacks on the production server namely:

- Greenbone Enterprise - The Greenbone Report will be provided as a separate attachment.
- Port Mapping – Nmap / Zenmap (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments – Tenable Nessus.

■ Port Mapping – Nmap / Zenmap

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

▼	Port	Protocol	State ▼	Service	Version
●	80	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
●	443	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
●	3306	tcp	open	mysql	MariaDB 5.5.5-10.4.8
●	3389	tcp	open	ms-wbt-server	Microsoft Terminal Services

Remote Operating System Detection:

- Used Port: 80/tcp (open)
- Used Port: 443/tcp (open)
- Used Port: 3306/tcp (open)
- Used Port: 3389/tcp (open)

We Recommend closing RDP (3389) or either of the following perform RDP is accessed:

- VPN with Certificate (not username and password combination)
- Configure Local Firewall to only accept RDP connections from known source address
- Install 2FA i.e. Google Authenticator.

■ Vulnerability Assessment – Tenable Nessus

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



102.67.139.234



Vulnerabilities

Total: 32

SEVERITY	CVSS V3.0	VDR SCORE	IPSS SCORE	BLUOIN	NAME
HIGH	7.5	6.1	0.406	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	4.0	-	-	58453	Terminal Services Doesn't Use Network Level Authentication (Only)
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	10719	MySQL Server Detection
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	66173	RDP Screenshot
INFO	N/A	-	-	10940	Remote Desktop Protocol Service Detection



INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	11153	Service Detection (HELP Request)
INFO	N/A	-	-	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	-	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	-	64814	Terminal Services Use SSL/TLS
INFO	N/A	-	-	10287	Traceroute Information

* indicates the v3.0 score was not available; the v2.0 score is shown

4.5 Ambledown UAT Server – 154.0.171.224

We have performed the following types of scans / attacks on the production server namely:

- Greenbone Enterprise - The Greenbone Report will be provided as a separate attachment.
- OWASP – The OWASP Report will be provided as a separate attachment.
- Port Mapping – Nmap / Zenmap (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments – Tenable Nessus.
- Brute Force Attacks – Hydra.

■ Port Mapping – Nmap / Zenmap

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:



▼	Port	Protocol	State ▼	Service	Version
●	21	tcp	open	ftp	Microsoft ftpd
●	80	tcp	open	http	Microsoft IIS httpd 8.0
●	110	tcp	open	pop3	hMailServer pop3d
●	143	tcp	open	imap	hMailServer imapd
●	443	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
●	3306	tcp	open	mysql	MariaDB 5.5.5-10.2.6

Remote Operating System Detection:

- Used Port: 21/tsp (open)
- Used Port: 80/tsp (open)
- Used Port: 110/tsp (open)
- Used Port: 143/tsp (open)
- Used Port: 443/tsp (open)
- Used Port: 3306/tsp (open)

As detected above, Windows 2012 is being used on the server. As per the Microsoft support lifecycle, there is no more support or updates available. It is critical to upgrade to a later version OS as soon as possible.

Should **Port 3306** not be needed over public access, the port ought to be closed. If **Port 3306** is needed over public access, we recommend it only be accessed over VPN or SSL Cert.

▪ Vulnerability Assessment – Tenable Nessus

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



154.0.171.224



Vulnerabilities

Total: 42

SEVERITY	CVSS V3.0	VDR SCORE	IPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	-	-	20007	SSL Version 2 and 3 Protocol Detection
HIGH	7.5	6.1	0.406	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.5	-	-	142960	HSTS Missing From HTTPS Server (RFC 6797)
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	5.9	7.3	0.9303	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
LOW	3.4	5.1	0.942	78479	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)
LOW	2.6*	-	-	54582	SMTP Service Cleartext Login Permitted
INFO	N/A	-	-	46180	Additional DNS Hostnames
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	10092	FTP Server Detection
INFO	N/A	-	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information



INFO	N/A	-	-	11414	IMAP Service Banner Retrieval
INFO	N/A	-	-	10719	MySQL Server Detection
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	50845	OpenSSL Detection
INFO	N/A	-	-	10185	POP Server Detection
INFO	N/A	-	-	54580	SMTP Authentication Methods
INFO	N/A	-	-	10263	SMTP Server Detection
INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	11153	Service Detection (HELP Request)
INFO	N/A	-	-	14773	Service Detection: 3 ASCII Digit Code Responses
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	11422	Web Server Unconfigured - Default Install Page Present

* indicates the v3.0 score was not available: the v2.0 score is shown



■ Brute Force

Randomised usernames with a word list containing more than 2.5 million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
(root@STKali)~  
# cat /usr/share/wordlists/dirb/big.txt | thc-pptp-bruter -u admin 41.169.103.84  
PPTP Connection established.  
Hostname '', Vendor 'Microsoft', Firmware: 0  
5 passwords tested in 0h 00m 00s (5.00 5.00 c/s)  
5 passwords tested in 0h 00m 05s (0.20 1.00 c/s)  
5 passwords tested in 0h 00m 10s (0.20 0.50 c/s)  
5 passwords tested in 0h 00m 15s (0.20 0.33 c/s)  
5 passwords tested in 0h 00m 20s (0.20 0.25 c/s)  
5 passwords tested in 0h 00m 25s (0.20 0.20 c/s)  
5 passwords tested in 0h 00m 30s (0.20 0.17 c/s)  
5 passwords tested in 0h 00m 35s (0.20 0.14 c/s)  
5 passwords tested in 0h 00m 40s (0.20 0.12 c/s)  
5 passwords tested in 0h 00m 45s (0.20 0.11 c/s)  
5 passwords tested in 0h 00m 50s (0.20 0.10 c/s)  
5 passwords tested in 0h 00m 55s (0.20 0.09 c/s)  
5 passwords tested in 0h 01m 00s (0.20 0.08 c/s)  
5 passwords tested in 0h 01m 05s (0.20 0.08 c/s)  
5 passwords tested in 0h 01m 10s (0.20 0.07 c/s)  
5 passwords tested in 0h 01m 15s (0.20 0.07 c/s)  
5 passwords tested in 0h 01m 20s (0.20 0.06 c/s)  
5 passwords tested in 0h 01m 25s (0.20 0.06 c/s)  
5 passwords tested in 0h 01m 30s (0.20 0.06 c/s)  
5 passwords tested in 0h 01m 35s (0.20 0.05 c/s)  
5 passwords tested in 0h 01m 40s (0.20 0.05 c/s)  
5 passwords tested in 0h 01m 45s (0.20 0.05 c/s)  
5 passwords tested in 0h 01m 50s (0.20 0.05 c/s)  
5 passwords tested in 0h 01m 55s (0.20 0.04 c/s)  
5 passwords tested in 0h 02m 00s (0.20 0.04 c/s)  
5 passwords tested in 0h 02m 05s (0.20 0.04 c/s)  
5 passwords tested in 0h 02m 10s (0.20 0.04 c/s)  
5 passwords tested in 0h 02m 15s (0.20 0.04 c/s)  
5 passwords tested in 0h 02m 20s (0.20 0.04 c/s)  
5 passwords tested in 0h 02m 25s (0.20 0.03 c/s)  
5 passwords tested in 0h 02m 30s (0.20 0.03 c/s)  
pptp connection dropped after 5 tries!  
Trying to reconnect....
```

As per the HYDRA screen shot above, all know accounts have been scanned and with no passwords found. We are satisfied with the results.



5 NETWORK CONFIGURATION AND SECURITY POLICIES

5.1 Internal Network Scan

The Internal Network Scan Report will be provided as a separate attachment.

5.2 Ambledown User List

Name	Type	Description
ABSA Gap Analysis - SCO'S Deny	Security Group - Global	
Administrator	User	Built-in account for administering the computer/domain
Allowed RODC Password Replication Group	Security Group - Domain Local	Members in this group can have their passwords replicated to all read-only domain controllers in the domain
Ambledown Exco	Security Group - Global	
Cert Publishers	Security Group - Domain Local	Members of this group are permitted to publish certificates to the directory
Denied RODC Password Replication Group	Security Group - Domain Local	Members in this group cannot have their passwords replicated to any read-only domain controllers in the domain
DHCP Administrators	Security Group - Domain Local	Members who have administrative access to DHCP service
DHCP Users	Security Group - Domain Local	Members who have view-only access to the DHCP service
DnsAdmins	Security Group - Domain Local	DNS Administrators Group
DnsUpdateProxy	Security Group - Global	DNS clients who are permitted to perform dynamic updates on behalf of some other clients (such as DHCP servers).
Domain Admins	Security Group - Global	Designated administrators of the domain
Domain Computers	Security Group - Global	All workstations and servers joined to the domain
Domain Controllers	Security Group - Global	All domain controllers in the domain
Domain Guests	Security Group - Global	All domain guests
Domain Users	Security Group - Global	All domain users
ensadmin	User	
Enterprise Admins	Security Group - Universal	Designated administrators of the enterprise
Enterprise Read-only Domain Controllers	Security Group - Universal	Members of this group are Read-Only Domain Controllers in the enterprise
Gaurdrisk Ambledown	Security Group - Global	
Gaurdrisk Broker	Security Group - Global	
Gaurdrisk CaseMan	Security Group - Global	
Gaurdrisk Claims	Security Group - Global	



Gaurdrisk Compliance	Security Group - Global	
Gaurdrisk Finance	Security Group - Global	
Gaurdrisk Manco	Security Group - Global	
Gaurdrisk Marketing	Security Group - Global	
Group Policy Creator Owners	Security Group - Global	Members in this group can modify group policy for the domain
Guest	User	Built-in account for guest access to the computer/domain
IUSR_WIN-EUGSO7LO7PY	User	Built-in account for anonymous access to Internet Information Services
Manco users	Security Group - Global	
Policies and Processors main	Security Group - Global	
Policies and Processors users	Security Group - Global	
RAS and IAS Servers	Security Group - Domain Local	Servers in this group can access remote access properties of users
Read-only Domain Controllers	Security Group - Global	Members of this group are Read-Only Domain Controllers in the domain
Schema Admins	Security Group - Universal	Designated administrators of the schema
SQLServer2005MSFTEUser\$S BSSRV\$MICROSOFT##SSEE	Security Group - Domain Local	
SQLServer2005MSFTEUser\$S BSSRV\$SBSMONITORING	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of SQL Server and SQL Server FullText Search in SQL Server 2005.
SQLServer2005MSSQLServerA DHelperUser\$SBSSRV	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of SQL Server Active Directory Helper in SQL Server 2005.
SQLServer2005MSSQLServerA DHelperUser\$WIN- EUGSO7LO7PY	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of SQL Server Active Directory Helper in SQL Server 2005.
SQLServer2005MSSQLUser\$S BSSRV\$MICROSOFT##SSEE	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of Windows Internal Database.
SQLServer2005MSSQLUser\$S BSSRV\$SBSMONITORING	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of SQL Server and SQL Server FullText Search in SQL Server 2005.



SQLServer2005SQLBrowserUser\$BSSRV	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of SQL Server Browser in SQL Server 2005.
SQLServer2005SQLBrowserUser\$WIN-EUGSO7LO7PY	Security Group - Domain Local	Members in the group have the required access and privileges to be assigned as the log on account for the associated instance of SQL Server Browser in SQL Server 2005.
Test	Distribution Group - Global	
Unity SFTP Users	Security Group - Global	
WSS_ADMIN_WPG	Security Group - Domain Local	Members of this group have write access to system resources used by Windows SharePoint Services.
WSS_RESTRICTED_WPG	Security Group - Domain Local	Group for the Windows SharePoint Services farm administrator. This group is required for the WSS Administration Service to function.
WSS_WPG	Security Group - Domain Local	Members of this group have read access to system resources used by Windows SharePoint Services.
WSUS Administrators	Security Group - Domain Local	WSUS Administrators can administer the Windows Server Update Services server.
WSUS Reporters	Security Group - Domain Local	WSUS Administrators who can only run reports on the Windows Server Update Services server.

5.3 Password Policies

- Complexity and known passwords we are comfortable with, we will however recommend extending the password length from 8 to 14 characters
- **Windows Server 2008 is used and there is no more support or updates to this software, upgrade to newer version as a matter of urgency.**
- Local firewall is disabled, enable and only allow services that is needed
- No Anti-Virus was detected or installed on the AD Server – Critical
- Consider changing the VPN from user/pass based authentication to user/cert-based authentication

Based on the previous reports dated April 2024, it was noticed that multiple recommendations were not implemented. We highly advise applying the relevant changes regarding the above.



5.4 Domain Policies

Account Policies/Password Policy	
Policy	Setting
Enforce password history	24 passwords remembered
Maximum password age	42 days
Minimum password age	0 days
Minimum password length	8 characters
Password must meet complexity requirements	Enabled
Store passwords using reversible encryption	Disabled
Account Policies/Account Lockout Policy	
Policy	Setting
Account lockout duration	0 minutes
Account lockout threshold	3 invalid logon attempts
Reset account lockout counter after	99999 minutes
Account Policies/Kerberos Policy	
Policy	Setting
Enforce user logon restrictions	Enabled
Maximum lifetime for service ticket	600 minutes
Maximum lifetime for user ticket	10 hours
Maximum lifetime for user ticket renewal	7 days
Maximum tolerance for computer clock synchronization	5 minutes
Local Policies/Audit Policy	
Policy	Setting
Audit account logon events	Success, Failure
Audit logon events	Success, Failure

As per the above screenshot and with the information disclosed, we are satisfied with the results, however, we do recommend extending the minimum password length from 8 characters to 14 characters.

5.5 Domain Admin Users

Members:	
Name	Active Directory Domain Services Folder
Administrator	ambledown.local/Users
Andrew Janse...	ambledown.local
Cyril De Jongh	ambledown.local/MyBusiness/Users/SBSUsers
Dataman	ambledown.local/MyBusiness/Users/SBSUsers
Donovan Olivier	ambledown.local/MyBusiness/Users/SBSUsers
Emmanuel Ma...	ambledown.local/MyBusiness/Users/SBSUsers
ensadmin	ambledown.local/Users
Eohadmin	ambledown.local/MyBusiness/Users/SBSUsers
Leota Pillay	ambledown.local/MyBusiness/Users/SBSUsers
Lukas	ambledown.local/MyBusiness/Users/SBSUsers
Morne Posthu...	ambledown.local/MyBusiness/Users/SBSUsers
Network Admi...	ambledown.local/MyBusiness/Users/SBSUsers
Nolan Naidoo	ambledown.local/MyBusiness/Users/SBSUsers



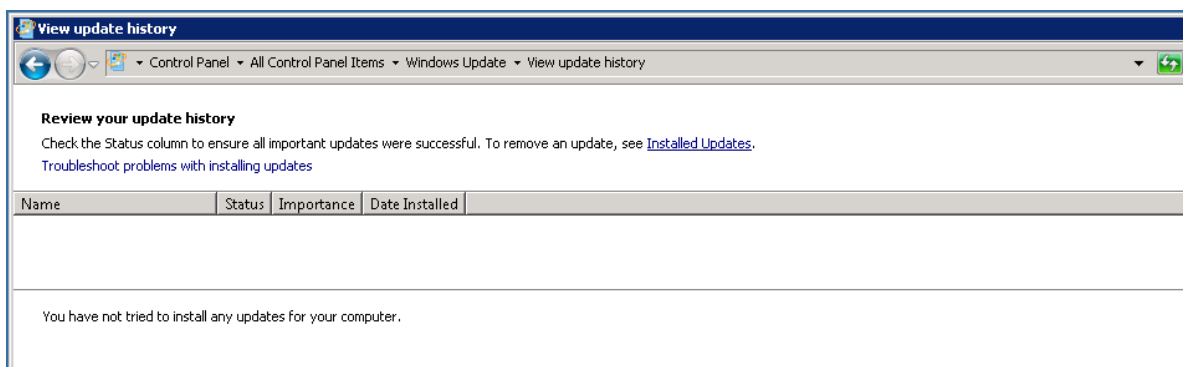
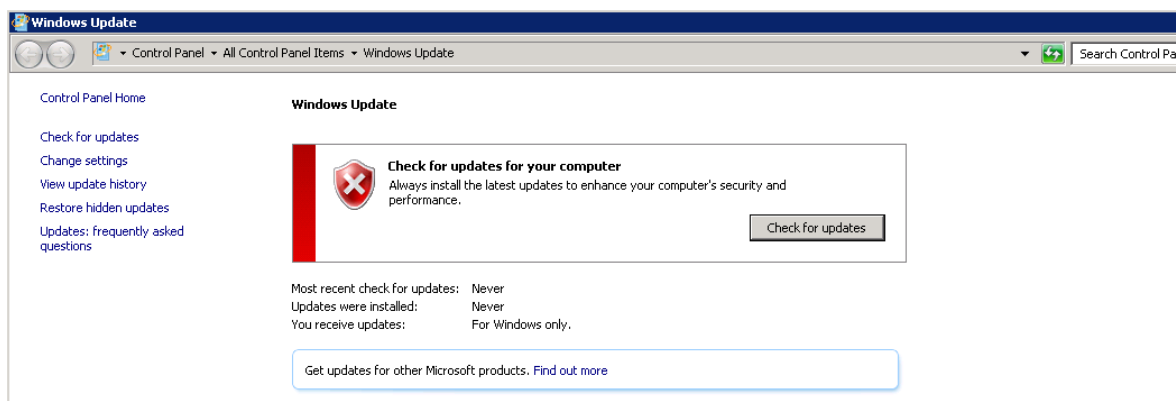
5.6 System Information

```
C:\Windows\system32\cmd.exe
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\Lukas>systeminfo

Host Name:                ADSERVER
OS Name:                  Microsoft Windows Server 2008 R2 Standard
OS Version:               6.1.7601 Service Pack 1 Build 7601
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Primary Domain Controller
OS Build Type:             Multiprocessor Free
Registered Owner:         Windows User
Registered Organization:
Product ID:                55041-014-3938005-84797
Original Install Date:    2014/03/01, 01:42:57 PM
System Boot Time:         2025/05/29, 10:24:51 AM
```

5.7 Server Windows Updates





5.8 Server OS

View basic information about your computer

Windows edition

Windows Server 2008 R2 Standard
Copyright © 2009 Microsoft Corporation. All rights reserved.
Service Pack 1



System

Processor: Intel(R) Xeon(R) CPU E5-2609 0 @ 2.40GHz 2.39 GHz
Installed memory (RAM): 7.81 GB
System type: 64-bit Operating System
Pen and Touch: No Pen or Touch Input is available for this Display

Computer name, domain, and workgroup settings

Computer name: ADSERVER
Full computer name: ADSERVER.ambledown.local
Computer description:
Domain: ambledown.local

[Change settings](#)

Windows activation

Windows is activated
Product ID: 55041-014-3938005-84797 [Change product key](#)



5.9 FortiGate Firewall

For Security reasons, we will not paste the firewall rules here, this can be obtained manually if need be.

We have only analysed the inbound rules as was the mandate and did not evaluate outbound, IPS or user policies. When we tried to login to the firewall, we were happy to note that entering the wrong password three times. We are also happy to know that the Web UI interface is not accessible via browser externally.

We cannot comment on rules created and why it's needed or not, but we do note there might be some rules that is old/outdated/not needed anymore. Although they pose no direct risk, we would disable/delete what is not needed.

On the rest of the firewall configuration, we are comfortable.

5.10 Firewall Information

The screenshot displays the FortiGate Web UI dashboard with the following sections:

- System Information:** Hostname: FortiGate-100F, Serial Number: FG100FTK23031915, Firmware: v6.4.16 build2098 (GA), Mode: NAT, System Time: 2025/05/29 11:42:44, Uptime: 32:22:33:49, WAN IP: 41.169.103.84.
- Licenses (173.243.129.6):** FortiCare Support, Firmware & General Updates, IPS, AntiVirus, Web Filtering, FortiToken (0/2).
- FortiGate Cloud:** Status: Activated, Server Location: Europe, Log Retention: Free License, Storage Used: 0B.
- Security Fabric:** FortiGate-100F, Security Fabric Connection is disabled.
- Administrators:** 1 HTTPS, 0 FortiExplorer, geust super_admin_readonly.



5.11 Wireless Network

We performed a wireless network scan/attack from Kali Linux.

The SSID should be hidden as its easy identifiable by name to which company it belongs and we could then detect easily what Encryption was used. Based on the encryption we knew the amount of characters that will be maximum and scanned the wireless network password.

Please consider changing the password to more Upper/lower/numeric/Symbolic Combinations. Also, please consider when the SSID is hidden, to install a guest WIFI off the main network, separate Vlan with breakout.

- Available Wireless SSID's:

```
[+] 1 attack(s) remain
[+] Do you want to continue attacking, or exit (c, e)? ^Cc
[+] Amb_Office_WiFi (31db) WPA Handshake capture: Discovered new client: 26:8D:23:9A:87:EE
[+] Amb_Office_WiFi (31db) WPA Handshake capture: Discovered new client: AC:F6:F7:BC:F7:C6
[+] Amb_Office_WiFi (31db) WPA Handshake capture: Discovered new client: F8:9E:94:CD:8B:65
[+] Amb_Office_WiFi (31db) WPA Handshake capture: Captured handshake
[+] saving copy of handshake to hs/handshake_AmbOfficeWiFi_94-A6-7E-B1-9F-BD_2024-04-17T07-09-25.cap saved

[+] analysis of captured handshake file:
[+] tshark: .cap file contains a valid handshake for (94:a6:7e:b1:9f:bd)
[+] aircrack: .cap file contains a valid handshake for (94:A6:7E:B1:9F:BD)

[+] Cracking WPA Handshake: Running aircrack-ng with wordlist-probable.txt wordlist
[+] Cracking WPA Handshake: 100.00% ETA: 0s @ 1587.0kps (current key: 12171984)
[!] Failed to crack handshake: wordlist-probable.txt did not contain password
[+] Finished attacking 1 target(s), exiting
```

- Wireless Password Brute Force Attack:

```
[+] analysis of captured handshake file:
[+] tshark: .cap file contains a valid handshake for (94:a6:7e:b1:9f:bd)
[+] aircrack: .cap file contains a valid handshake for (94:A6:7E:B1:9F:BD)

[+] Cracking WPA Handshake: Running aircrack-ng with wordlist-probable.txt wordlist
[+] Cracking WPA Handshake: 0.00% ETA: 11m18s @ 300.4kps (current key: )
[+] Cracked WPA Handshake PSK: 3ns3rv1c3swifi

[+] Access Point Name: Amb_Office_WiFi
[+] Access Point BSSID: 94:A6:7E:B1:9F:BD
[+] Encryption: WPA
[+] Handshake File: hs/handshake_AmbOfficeWiFi_94-A6-7E-B1-9F-BD_2024-04-17T07-57-25.cap
[+] PSK (password): 3ns3rv1c3swifi
[+] saved crack result to cracked.json (1 total)
[+] Finished attacking 1 target(s), exiting
```

Based on the previous reports dated April 2024, it was noticed that the Wireless Key has still not been changed and the Wireless SSID has still not been hidden. We highly recommend applying the relevant changes regarding the above.



6 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view that from External Testing where the SSH port are not open to public, these vulnerabilities then become academic. However, we still recommend that the changes be implemented. Ambledown Financial Services is behind the managed FortiGate firewall.

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a Hosted Infrastructure point of view, we are happy with the results. We do recommend that SentinelOne is implemented into the production environment as soon as possible. We also recommend where Operating systems are end of life or close to, they be upgraded.

As stated, based on the previous reports dated April 2024, multiple recommendations and changes were not implemented. We highly advise applying same as soon as possible.

Eleven (11) addendum reports are attached to this report and should be read as one document.

Two separate folders are included:

Folder 1: Public IP Scan – Main

Contains scan results performed directly from a public IP to target public IP addresses.

- Ambledown HO Firewall – GREENBONE
- Ambledown HO Firewall – NESSUS
- Ambledown HO Firewall – OWASP
- Ambledown Live Server – GREENBONE
- Ambledown Live Server – NESSUS
- Ambledown UAT Server – GREENBONE
- Ambledown UAT Server – NESSUS
- Ambledown UAT Server – OWASP

Folder 2: Internal IP Scan – Main

Contains scan results from allowed public IPs to internal production server IPs

- Ambledown Domain Controller – GREENBONE
- Ambledown Firewall Internal – GREENBONE
- Ambledown Internal Network Scan

With the following test performed:

- Network scanning
- Known network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports i.e.: ssh open



7 AUDITORS

These audits were concluded over a period of seven (7) business days.
We hereby confirm that the above information is true and correct:

05th June 2025 – Krugersdorp, South Africa

Riaan van Jaarsveld
Security Expert – CCSA / Certified Pen Tester

Lukas Janse van Rensburg
Security Engineer